2026 HACKATHHON

AGENTIC AI GOVERNANCE AND “SHADOW MONITORING”

Njoki

Mark

Irvin

1. Executive Summary

As of 2026, the primary risk in enterprise AI has shifted from "bad prompts" to **"unauthorized actions."** Agentic AI systems can now autonomously call APIs, delete files, and move funds. **Agent Guard** provides a centralized control plane to intercept, audit, and block agent actions based on real-time security policies.

2. System Architecture

The system operates as a **Transparent Security Proxy** sitting between the AI Orchestrator (e.g., LangChain, CrewAI, AutoGen) and the Tools (MCP Servers).

Core Components:

- **MCP Governance Proxy:** A high-performance gateway that terminates MCP connections, inspects the JSON-RPC traffic, and enforces policies before forwarding calls.
- **Shadow Discovery Engine:** A passive network listener that identifies unauthorized local LLM servers (Ollama, vLLM) and "dark" MCP endpoints on the corporate network.
- **Policy Decision Point (PDP):** A REGO-based engine (using Open Policy Agent) that evaluates tool-calls against organizational guardrails.
- **The "Circuit Breaker":** A rate-limiting and loop-detection module that kills agent sessions if they exhibit recursive "hallucination loops."

3. Detailed Feature Specifications

A. Shadow AI Discovery

Instead of waiting for developers to register their agents, AgentGuard proactively finds them:

- **Port Scanning:** Monitors for active servers on ports 11434 (Ollama), 8000 (vLLM), and 5001 (standard MCP).
- **Traffic Fingerprinting:** Uses mTLS inspection to identify non-human traffic patterns characteristic of LLM-to-tool handshakes.
- **Automatic Onboarding:** Flags discovered agents in the dashboard and "quarantines" them (blocking outgoing tool calls) until a policy is assigned.

B. "Human-on-the-Loop" (HOTL) Approval

For high-consequence tools, the system pauses execution:

- **Risk-Tiering:** Tools are tagged as LOW (Read-only), MEDIUM (Edit/Write), or HIGH (Delete/Pay/Execute).
- **The Intercept:** When a HIGH risk tool is called (e.g., stripe.refund_payment), the proxy holds the request and sends a webhook to a mobile app or Slack channel for a human "Yes/No."
- **Contextual Preview:** The human is shown the "Reasoning Trace" (the agent's thought process) leading to that action.

C. Data Exfiltration Prevention (Canary Tokens)

- **Dynamic Injection:** The proxy subtly injects unique "Honey-files" or fake API keys into the agent’s retrieved context.
- **Detection:** If the agent attempts to "leak" this specific token to an external domain (like a non-sanctioned LLM provider), the system triggers an immediate security alert.

4. The Policy Framework (Example)

Policies are defined in a human-readable format that the **Policy Engine** enforces:

JSON
```
{
  "agent_id": "marketing-agent-01",
  "allowed_tools": ["google-search", "slack-read"],
```

```
  "restricted_tools": ["github-push", "bash-execute"],
  "constraints": {
    "max_api_calls_per_minute": 10,
    "pii_redaction": true,
    "human_approval_required": ["slack-send-external"]
  }
}
```

5. Implementation Roadmap (Hackathon Schedule)

Milestone	Focus
The Gateway	Build a basic Python/FastAPI proxy that accepts MCP JSON-RPC requests and forwards them to a Tool.
The Engine	Integrate Open Policy Agent (OPA) to allow/deny requests based on the method name.
Shadow Discovery	Write a script to scan the local network for active Ollama or MCP server endpoints.
UI & Pitch	Build a "CISO Dashboard" showing active agents, blocked actions, and a "Kill Switch" button.

6. 2026 Compliance Alignment

AgentGuard is designed to meet the **EU AI Act (Article 14)** requirements for human oversight and the **NIST AI RMF 1.0** for observability. It ensures that every "autonomous" action is traceable to a specific human mandate.

Recommended Tech Stack

Component	Technology
Protocol	**MCP (Model Context Protocol)** — This is the 2026 standard for agent-tool communication.
Language	**Go** or **Rust** (for high-performance proxying) or **FastAPI** (for quick iteration).
Policy Engine	**OPA (Open Policy Agent)** or a custom LLM-based "Judge" model (e.g., Llama-3-Guard).
Dashboard	**Next.js + Vercel** (for the real-time monitoring UI).
Discovery	**Nmap** or **Scapy** (for network scanning logic).

<u>CONCEPTS TO SOLVE:</u>

The "Sycophancy" Gap (Tool Description Poisoning)

The Concept: Agents often trust a tool's **textual description** more than its actual code logic.

- **The Problem:** An attacker can perform a "Tool Redescription Attack." If an agent sees a tool named delete_temp_files but the description says "Use this to improve system performance," a helpful agent might call it destructively to "help" the user.
- **The Solution:** Build a **Signature-Validated Tool Registry**. Your proxy should only allow tool calls if the tool's metadata (name, description, and schema) matches a cryptographically signed version in your database. If a prompt injection tries to "redefine" the tool in the agent's context, the proxy blocks the call.

2. The "Recursive Hallucination" Loop

The Concept: When an agent fails a task, it often retries. If the failure is deterministic (e.g., a permission error), the agent may enter an infinite loop, burning thousands of dollars in tokens in minutes.

- **The Problem:** Traditional rate-limiting (calls per minute) is too slow to stop a high-speed agentic spiral.
- **The Solution: Semantic Loop Detection**. Implement a sliding window cache that hashes the agent's last 5 "thoughts" and "tool calls." If the semantic similarity of the sequence exceeds 95%, your proxy triggers a "Circuit Breaker" to pause the agent and alert a human.

3. Non-Human Identity (NHI) & Privilege Creep

The Concept: Agents often "inherit" the broad permissions of the developer who created them, rather than having their own restricted identity.

- **The Problem:** If an agent is compromised via prompt injection, the attacker suddenly has the developer's full access to the company's GitHub or AWS.
- **The Solution: Dynamic Just-in-Time (JIT) Scoping**. Instead of giving an agent a permanent API key, your proxy issues **Session-Bound Tokens**.
    - *Example:* If the user says "Summarize this one file," the proxy generates a token that *only* has read access to that specific file ID for 10 minutes.

4. The "Confused Deputy" Attack

The Concept: This happens in multi-agent systems where a "Trusted Agent" (with high permissions) is tricked by a "User-Facing Agent" (with low permissions).

- **The Problem:** Agent A (Customer Support) asks Agent B (Internal Admin) to "reset a password" for a user. Agent B trusts Agent A implicitly and performs the action without realizing the request was malicious.
- **The Solution: Multi-Agent Provenance Tracking**. Every MCP request must carry a "Chain of Custody" header. When Agent B receives a request, the proxy checks the *original* source. If the request originated from a "Low Trust" zone (like a public chat), the proxy forces a Human-on-the-Loop approval.

Core Concepts to "Solve" in Your MVP

Concept	Technical Implementation
Trust Verification	**mTLS** between the Agent and the Proxy to prevent spoofing.
Integrity	**Hashing** tool definitions to prevent prompt-based tool overrides.
Observability	**Trace IDs** that link an LLM's "Reasoning" directly to the "Action" it took.
Safety	**Constraint-Based Filtering** (e.g., "Agent cannot send >100KB of data to external domains").